



Weekly Cyber Threat Intelligence Report

Reporting window: 16 - 22 June 2026

Australia - APAC - Global - Emerging Threats - IOCs to Add

Prepared for: Jordan

Classification: TLP:CLEAR - cleared for public release

Source: CyberSec Vault automated intel sweep

PUBLIC

Executive Summary

8 Critical CVEs	8 Actively exploited	9 Malware/campaigns	5 Notable breaches	10 PoCs / tools	18 IOCs to add
--------------------	-------------------------	------------------------	-----------------------	--------------------	-------------------

This week was dominated by **actively-exploited web and enterprise vulnerabilities**, **trusted-infrastructure C2 with BYOVD EDR-killers**, and **AI surfacing as both target and attacker tooling**. Mass exploitation hit internet-facing apps: Joomla JCE (**CVE-2026-48907**, CVSS 10, public exploit, automated), Splunk (**CVE-2026-20253**), F5 NGINX (**CVE-2026-42530/42055**), Oracle WebCenter Sites (**CVE-2026-46798**), Cisco Catalyst SD-WAN (**CVE-2026-20262**, KEV 0-day), Jenkins (**CVE-2026-53435**) and Gravity SMTP (**CVE-2026-4020**, 17M+ blocked attempts). The **FortiBleed** Fortinet-credential campaign kept widening - now with rented-GPU hash cracking. Ransomware leaned on stealth: **DragonForce's** Backdoor.Turn tunnels C2 through Microsoft Teams TURN relays, **The Gentlemen** ship a GentleKiller BYOVD EDR-killer suite (400 procs/48 products), and **INC** (800+ victims, Rust encryptors) lists Australia as its #2 target. Microsoft detailed the **CryptoBandits** USB-worm Tor clipper, and law enforcement disrupted **SocGholish** (Operation Endgame). On AI: unpatched **Spyder/MaXSS** flaws in SiderAI/MaxAI (10M+ installs), and DPRK's **Sapphire Sleet** poisoned 140+ Mastra npm packages. China-nexus **SprySOCKS** gained a Windows kernel-rootkit variant, and the **usbliter8** unpatchable A12/A13 BootROM exploit went public. **Items are ordered verified-first, each with up to three independent references**; public PoCs/tools and indicators to block are in their own sections.

AUSTRALIA - SPECIFIC

Local orgs & data

TEG / Ticketek (AU) - 26M+ user records re-advertised on a cybercrime forum

HIGH

UNVERIFIED

Breach

Australia

PII

A threat actor is advertising a claimed TEG (Ticketek Entertainment Group) dataset of 26M+ records (names, emails, phones, possibly hashed creds / partial payment metadata) on an underground forum. The figure and fields closely match TEG's confirmed 2024 third-party-cloud breach (~30M records, actor 'Sp1d3r'), so this 2026 listing is most likely a recompilation/re-sale of that earlier data rather than a fresh intrusion - still usable for phishing, credential stuffing and fraud against Australian customers. The new listing itself is single-source; retained UNVERIFIED pending confirmation it is new data.

Refs: [x.com/DailyDarkWeb](#) · [securityweek.com](#) · [darkreading.com](#)

APAC - SPECIFIC

Regional incidents & actors

Mastra AI (npm) supply-chain attack attributed to North Korea (Sapphire Sleet / BlueNoroff)

HIGH

VERIFIED

DPRK

SupplyChain

npm

Microsoft attributes the compromise of 140+ npm packages in the @mastra scope to DPRK actor Sapphire Sleet (BlueNoroff). Attackers hijacked maintainer account 'ehindero' and pushed malicious updates injecting a fake dependency 'easy-day-js' (typosquatting dayjs). A postinstall hook ran an obfuscated dropper that disabled TLS verification, beacons to C2, and deployed an infostealer targeting 166 crypto-wallet browser extensions across Windows/Linux/macOS. Same actor tied to the April 2026 Axios npm attack. Audit @mastra deps, pin/verify hashes, rotate developer & wallet secrets.

Refs: [bleepingcomputer.com](#) · [thehackernews.com](#) · [windowsreport.com](#)

SprySOCKS backdoor ported Linux -> Windows (FishMonger / China-nexus, kernel-driver rootkit)

HIGH

VERIFIED

APT

China

Rootkit

ESET found two undocumented Windows variants of SprySOCKS (WIN_DRV, WIN_PLUS), attributed to FishMonger - the China-based group linked to contractor I-Soon. WIN_DRV ships a kernel-driver rootkit that hides files, processes, registry keys and network connections, plus TCP traffic diversion to mask its listening port; both support TCP/UDP/WebSocket C2. Telemetry traced 2023-2024 activity against government bodies in Honduras, Taiwan, Thailand and Pakistan. Detection needs driver-integrity / rootkit hunting, not file IOCs alone.

Refs: [thehackernews.com](#) · [welivesecurity.com](#) · [darkreading.com](#)

China dismantles 'Silver Fox' trojan cells across five provinces (439-domain CNCERT campaign)

MEDIUM

UNVERIFIED

China

Takedown

Trojan

A single vault source reports China detained dozens tied to Silver Fox (SwimSnake / Void Arachne-adjacent) phishing operations and a 439-domain campaign tracked by CNCERT. Silver Fox is a well-documented China-nexus RAT operator (ValleyRAT/Winos 4.0, AtlasCross), but the specific June 2026 takedown (five provinces / 439 domains) could not be corroborated by independent English-language reporting - retained UNVERIFIED. Continue blocking known Silver Fox C2/phishing infrastructure and watch for successor domains.

Refs: [x.com/the_yellow_fall](#)

GLOBAL - ACTIVELY EXPLOITED & CRITICAL CVEs

[Patch now](#)**CVE-2026-48907 - Joomla Content Editor (JCE) improper access control -> PHP RCE (CVSS 10.0), mass-exploited**

CRITICAL

VERIFIED

CMS

RCE

Exploited

Improper access control in the Widget Factory JCE plugin lets unauthenticated attackers create editor profiles to upload and run PHP code (CVSS 10.0). Affects JCE 1.0.0-2.9.99.4; fixed in 2.9.99.5 (3 Jun). CISA added it to KEV with a patch-by-Friday federal deadline. Joomla warns exploit code is public and attacks are automated, so even sites without public registration are at risk. Patch now and hunt for webshells/anomalous uploads - compromise may predate patching.

PoC: Public - working exploit code public; automated attacks (CISA KEV)Refs: thehackernews.com · bleepingcomputer.com · scworld.com**CVE-2026-42530 / CVE-2026-42055 - F5 NGINX critical RCE (HTTP/3 UAF + HTTP/2 heap overflow), CVSSv4 9.2**

CRITICAL

VERIFIED

WebServer

RCE

Unauth

F5 shipped out-of-band patches for two unauthenticated, remotely triggerable NGINX flaws (both CVSSv4 9.2). CVE-2026-42530 is a use-after-free in ngx_http_v3_module (HTTP/3 QUIC) - a crafted session reopens a QPACK encoder stream, crashing the worker and, if ASLR is bypassed, enabling RCE (affects NGINX OSS 1.31.0/1.31.1, fixed 1.31.2; mitigate by disabling HTTP/3). CVE-2026-42055 is a heap overflow in the HTTP/2 proxy/gRPC path (fixed OSS 1.30.3/1.31.2, Plus R37 P2.1 / R36 P6). Patch and review HTTP/2-3 config.

PoC: Public - PoC referenced for CVE-2026-42530 (HTTP/3 UAF) - x.com/akaclandestineRefs: securityweek.com · thehackernews.com · bleepingcomputer.com**CVE-2026-20253 - Splunk Enterprise unauth file create/truncate -> RCE (CVSS 9.8), actively exploited**

CRITICAL

VERIFIED

SIEM

RCE

Exploited

A built-in PostgreSQL sidecar endpoint exposed with zero authentication lets unauthenticated attackers create/truncate arbitrary files on Splunk Enterprise, chaining to RCE (CVSS 9.8). Splunk now reports limited exploitation in the wild and CISA has issued a high-priority alert. Affects versions below 10.2.4 / 10.0.7 - patch now and keep management / DB (PostgreSQL sidecar) ports off untrusted networks.

PoC: Active exploitation in the wild (CISA alert)Refs: thehackernews.com · securityweek.com · x.com/SecurityWeek**CVE-2026-46798 - Oracle WebCenter Sites unauth RCE / full takeover (CVSS 9.8)**

CRITICAL

VERIFIED

Enterprise

RCE

Unauth

A maximum-severity flaw in Oracle WebCenter Sites lets a remote, unauthenticated attacker compromise the product over HTTP with no user interaction, leading to full takeover (CVSS 9.8; SecAlerts framed it as 'CVSS 10'). Addressed in the Oracle June 2026 Critical Patch Update (Oracle's CVE-to-advisory map also lists a closely matching WebCenter Sites unauth-RCE as CVE-2026-35293). Patch all 12.2.1.4.0 / 14.1.2.0.0 instances immediately, restrict admin interfaces, and hunt for webshells given the unauth/no-UI profile.

Refs: oracle.com · radar.offsec.com · x.com/SecAlertsCo**Windows Defender 'RoguePlanet' 0-day - public working exploit grants SYSTEM (Chaotic/Nightmare Eclipse)**

CRITICAL

VERIFIED

Windows

PrivEsc

EDR-Bypass

The 'Chaotic Eclipse' researcher publicly released 'RoguePlanet', a working exploit abusing Microsoft Defender to escalate to SYSTEM. Microsoft has confirmed the Windows full-PC-access 0-day and says a fix is in progress. Latest in the recurring Defender 'Eclipse' 0-day cluster - treat as actively weaponised; keep Defender platform current and hunt for Defender process anomalies / unexpected SYSTEM escalations.

PoC: Public - SYSTEM exploit (Chaotic Eclipse); Microsoft confirms, fix in progress - bleepingcomputer.comRefs: bleepingcomputer.com · x.com/Malwarebytes · x.com/TheHackersNews

CVE-2026-53435 - Jenkins deserialization (CVSS 8.8), actively exploited; Nuclei template public

HIGH

VERIFIED

CI/CD

Deserialization

Exploited

A high-severity deserialization flaw in Jenkins (CVSS 8.8) is under active exploitation. Jenkins is a high-value CI/CD target for initial access, credential theft and supply-chain pivoting. Apply the 2026-06-10 advisory patches, keep controllers off the internet, scan with the published Nuclei template, and hunt for anomalous job/plugin creation and outbound connections from build nodes.

PoC: Public - Nuclei detection template (rxerium 2026/CVE-2026-53435.yaml) - [github.com](#)

Refs: [jenkins.io](#) · [github.com](#) · [x.com/rxerium](#)

CVE-2026-20262 - Cisco Catalyst SD-WAN Manager arbitrary file write -> root, exploited as 0-day (CISA KEV)

MEDIUM

VERIFIED

Appliance

FileWrite

Exploited

An authenticated low-priv attacker can create/overwrite OS files via a crafted upload request to Catalyst SD-WAN Manager (CVSS 6.5), escalating to root - exploited as a zero-day before patch availability and added to CISA KEV (federal fix-by 29 Jun). Hunt /var/log/nms/vmanage-server.log for path-traversal patterns and rogue .war deployments to the WildFly deployments dir (classic webshell/RCE staging). Despite the Medium base score, active exploitation makes this urgent.

PoC: Active exploitation in the wild (limited, targeted; fix-by 2026-06-29)

Refs: [thehackernews.com](#) · [securityweek.com](#) · [securityaffairs.com](#)

CVE-2026-4020 - Gravity SMTP WordPress plugin unauth info disclosure (~100k sites), mass-exploited

MEDIUM

VERIFIED

WordPress

InfoDisclosure

Exploited

An exposed REST endpoint in Gravity SMTP (permission_callback always returns true) lets unauthenticated GET requests pull a full 'System Report' exposing API keys, OAuth tokens and secrets for SES/Google/Mailjet/Resend/Zoho plus server/DB/plugin details. Affects versions <=2.1.4 (fixed 2.1.5). Defiant/Wordfence blocked 17M+ exploit attempts (spiking 7 Jun). IOC: requests to /wp-json/gravitysmtp/v1/tests/mock-data. Update now and rotate any exposed mail-integration keys.

PoC: Active mass exploitation (Wordfence blocked 17M+ attempts)

Refs: [bleepingcomputer.com](#) · [thehackernews.com](#) · [cybersecuritynews.com](#)

GLOBAL - OTHER NOTABLE VULNERABILITIES

High severity

'Spyder' & 'MaXSS' - critical flaws in AI 'agentic side panel' extensions SiderAI / MaxAI (10M+ installs)

HIGH

VERIFIED

Browser

Extension

Unpatched

Rebora Security disclosed Spyder (SiderAI) and MaXSS (MaxAI) in agentic AI side-panel extensions with 10M+ combined installs on Chromium browsers (SiderAI is a top-25 Chrome Web Store extension). Both fail to validate input from web pages to content scripts: a malicious site can simulate clicks/keystrokes, silently open services like Gemini, extract private AI conversations, read emails, steal auth tokens and act as the user across sites. Both remain UNPATCHED after vendors did not respond - consider removing/restricting these extensions.

PoC: Unpatched - vendors unresponsive to disclosure

Refs: [cybersecuritynews.com](#) · [rebora.io](#) · [gbhackers.com](#)

Unpatched NTLM coercion via Windows 'search:' URI handler (no CVE, no fix)

HIGH

VERIFIED

Windows

NTLM

NoFix

A coercion bug in the Windows search: URI handler captures NTLMv2 hashes with a single click - no download, no malware. Researchers note the primitive is technically identical to CVE-2026-33829 (Snipping Tool) - same mechanism and impact - yet Microsoft closed it without a CVE or patch as 'case-by-case'. The handler behaviour remains unfixed; mitigate by blocking outbound SMB/445, disabling NTLM, enabling EPA and monitoring search: invocations.

Refs: [huntress.com](#) · [x.com/7h3h4ckv157](#) · [x.com/0x534c](#)

CVE-2025-20701 - Airoha SoC Bluetooth lets in-range attacker eavesdrop via Beats Studio Buds mic

HIGH

VERIFIED

Bluetooth

Eavesdrop

IoT

A missing-authentication weakness in the Airoha SoC Bluetooth radio (CVSS 8.8) lets an attacker within Bluetooth range listen through the microphone of an earbud that is unpaired and seeking pairing. Disclosed by ERNW (Heinze, Steinmetz) at TROOPERS alongside CVE-2025-20700/20702. Update Beats Studio Buds to firmware 1B211 (auto-updates near a paired Apple device); for other affected brands apply latest firmware and pair only in trusted environments.

Refs: thehackernews.com · bleepingcomputer.com · scworld.com

CVE-2026-28575 - Android PackageInstaller.Session#transfer memory exhaustion (local DoS)

MEDIUM

UNVERIFIED

Android

DoS

Mobile

A logic error in Android's PackageInstaller.Session#transfer (PackageInstallerSession.java) causes memory exhaustion. Per the Android bulletin description it leads to LOCAL denial of service with no additional execution privileges and no user interaction - the early 'CVSS 10 / full system impact' framing from the original X post is NOT supported by the bulletin and is corrected here. Review the June 2026 Android Security Bulletin and apply the patch level; impact is DoS, not RCE. Retained UNVERIFIED pending broader independent reporting.

Refs: x.com/SecAlertsCo · cvedetails.com

GLOBAL - SOFTWARE SUPPLY CHAIN

OAuth / integration

Klue integration breach -> Salesforce OAuth-token theft ('Icarus' extortion)

HIGH

VERIFIED

SaaS

OAuth

SupplyChain

Attackers compromised Klue's backend (via a dormant prototype credential) and pushed a malicious update that stole customer OAuth tokens used to link Klue Battlecards to Salesforce, then queried connected Salesforce orgs directly - inheriting authorised access without tripping primary-app auth. Disclosed victims include Recorded Future, Tanium, Jamf, Sprout Social, Gong and Insurity; the new 'Icarus' group (launched Apr 2026) is extorting customers. Salesforce disabled the integration. Revoke/rotate OAuth tokens and review Salesforce API logs - continuation of the Salesloft/Drift integration-token pattern.

Refs: bleepingcomputer.com · thehackernews.com · darkreading.com

GLOBAL - PUBLIC PoCs & OFFENSIVE TOOL RELEASES

PoC / exploit code & tools

usbliter8 - public unpatchable SecureROM/BootROM exploit for Apple A12/A13 (USB DFU)

WATCH

VERIFIED

PoC

BootROM

Apple

Paradigm Shift published usbliter8 (vault tracked it as 'usblter8'), a checkm8-style mask-ROM exploit achieving code execution in SecureROM on A12/A13 chips (iPhone XS/XR/11, some iPad/Apple Watch). It combines a USB-controller hardware flaw with a DMA buffer underflow over DFU, completes in <2s before the signed boot chain loads, and cannot be patched in software. Physical access required; Secure Enclave remains a separate boundary. Risk is to lost/seized/second-hand devices - enforce strong passcodes; mitigation is A14+ hardware.

PoC: Public - working exploit released 18 Jun (Paradigm Shift) - thehackernews.com

Refs: thehackernews.com · appleinsider.com · 9to5mac.com

V8 JIT f64mod fast-path range confusion - browser exploit primitive (caught pre-stable)

WATCH

UNVERIFIED

PoC

Browser

V8

Researcher detailed an ARM64 V8 JIT f64mod fast-path range-confusion bug (L-trunc(L/R)*R) that yields a type-confusion exploitation primitive in the JS engine; reported as crbug 488078904 and caught before reaching stable Chrome. Useful context for browser-exploit detection engineering. Single-source technique writeup (unverified).

Refs: crbug.com · x.com/itszn13

CyberStrike - AI offensive-security agent reportedly used by the FortiBleed actor

WATCH

UNVERIFIED

Tool

AI

Offensive

@vysecurity reported the FortiBleed operator using 'CyberStrike', an autonomous AI offensive agent advertising 7,300+ actions, to operationalise recon-to-credential-harvesting at scale. Data point in the trend of attackers wiring LLM agents into end-to-end offensive workflows. Single-source (unverified).

Refs: x.com/vysecurity

EDRChoker - Policy-QoS EDR throttling (bypass) tool

WATCH

UNVERIFIED

Tool

EDR-Bypass

RedTeam

Open-source red-team tool that abuses Windows Policy-Based QoS to starve EDR processes of network/CPU rather than killing/injecting - the agent keeps running while telemetry/C2 times out (throttled to ~8 bps). Two independent sources but vault tool release; retained UNVERIFIED. Hunt for unexpected QoS policy objects affecting security-agent traffic.

Refs: cybersecuritynews.com · thehackernews.com · x.com/TheHackersNews

CyberSentinel AI v3.0 - autonomous pentest platform bundling 33 tools in Kali Docker

INFO

UNVERIFIED

Tool

AI

Recon

Open-source platform that actually executes 33 integrated pentest/TI tools (Nmap, SQLMap, Nikto, Nuclei, OWASP ZAP) inside an isolated Kali Docker sandbox and uses an LLM (Claude/GPT/Ollama) to interpret output in real time. Dual-use: red-team acceleration and an emerging autonomous-attack capability. Single-source release (unverified).

Refs: cybersecuritynews.com · x.com/The_Cyber_News

Storm-Breaker - webcam/mic/location phishing toolkit

INFO

UNVERIFIED

Tool

Phishing

SocEng

Open-source social-engineering toolkit that generates phishing pages which, on browser-permission grant, capture victim webcam, microphone, location and device info (typically Ngrok-tunnelled). For red-team / awareness use; defenders should brief staff on permission-prompt phishing. Single-source mention (unverified).

Refs: github.com · x.com/tom_doerr

Param Miner - background header/param brute-forcer for web cache poisoning (Burp ext)

INFO

UNVERIFIED

Tool

WebSec

BugBounty

Burp Suite extension that brute-forces unknown header/parameter names in the background and reports hidden/unkeyed inputs influencing cached responses - a strong aid for finding web cache poisoning. Defensive teams can use it to test their own caching layers. Single-source mention (unverified).

Refs: x.com/WebSecAcademy

Matkap - OSINT hunter for exposed malicious Telegram bot tokens

INFO

UNVERIFIED

Tool

OSINT

Defense

Python OSINT tool that hunts exposed malicious Telegram bot tokens / chat IDs via FOFA and URLScan, then analyses/exports captured bot activity - useful for tracking malware that exfiltrates to Telegram (a common C2/exfil channel). Single-source mention (unverified).

Refs: x.com/DarkWebInformr

PysistenceSniper - offline Windows persistence detection (DFIR)

INFO

UNVERIFIED

Tool

DFIR

Defense

Defensive tool that detects Windows persistence offline against a Velociraptor collection or a mounted disk image in seconds - no live access, no admin, no PowerShell required. Suited to IR triage of acquired images. Single-source mention (unverified).

Refs: x.com/7h3h4ckv157

GLOBAL - MALWARE & CAMPAIGNS

AryStinger - botnet conscripts 4,300+ legacy D-Link routers into a recon/proxy network

HIGH

VERIFIED

Botnet

Router

Proxy

AryStinger compromises EOL SOHO routers (D-Link DIR-850L/DIR-818LW) via old flaws (CVE-2013-3307, CVE-2016-5681, CVE-2025-11837), turning 4,300+ devices into 'executors' for scanning, proxying, tunnelling and remote command execution - pre-intrusion infrastructure that blends into residential IP space; it can also tamper with DNS. Two variants (C for routers, Go for NAS). Qianxin/XLab telemetry concentrates infections in South Korea (~48%) and China (~32%) - heavy APAC footprint. Retire EOL routers; block AryStinger C2.

Refs: thehackernews.com · bleepingcomputer.com · techtimes.com

DragonForce 'Backdoor.Turn' - Go RAT tunnels C2 through Microsoft Teams TURN relays

HIGH

VERIFIED

Ransomware

C2-Evasion

LOTS

DragonForce used a custom Go backdoor (Backdoor.Turn) that obtains an anonymous Teams visitor token, sets up a connection via a legitimate Microsoft TURN relay, then runs a QUIC session to the real C2 - the first observed in-the-wild abuse of TURN relays for C2, so defenders only see traffic to legitimate Teams servers. In one case the group dwelt ~2 months (entry via unpatched MSSQL, 4 BYOVD EDR-kills) before encrypting. Backdoor.Turn supports command exec, AD/LDAP search, lateral movement and browser-cred theft.

Refs: security.com · thehackernews.com · securityweek.com

The Gentlemen RaaS - 'GentleKiller' BYOVD EDR-killer suite (400 procs / 48 products)

HIGH

VERIFIED

Ransomware

EDR-Killer

BYOVD

ESET details The Gentlemen RaaS shipping affiliates an in-house EDR-killer framework, GentleKiller, with 8+ variants each impersonating a legitimate security product and abusing a distinct vulnerable kernel driver (BYOVD) to disable defences before encryption - targeting ~400 processes across 48 security products. It folds in third-party killers (HexKiller/ThrottleBlood/HavocKiller) and adopted public PoCs (UnknownKiller, PoisonKiller) within days. A May 2026 internal leak confirmed active development. Enable driver blocklists / vulnerable-driver hunting and tamper protection.

Refs: welivesecurity.com · thehackernews.com · helpnetsecurity.com

INC ransomware - 800+ victims, Rust Windows/Linux-ESXi encryptors, Veeam DPAPI cred theft

HIGH

VERIFIED

Ransomware

Rust

Veeam

Acronis reports INC has matured into a top-tier RaaS with 800+ (830) victims since 2023, filling the gap left by LockBit/BlackCat. Both Windows and Linux/ESXi encryptors are now rewritten in Rust (harder analysis, cross-platform), and a refined credential dumper targets newer Veeam backups protected by salted DPAPI. Notably, Australia is reported as the second-most-targeted country. Patch/segment Veeam, protect backups (immutable/offline), and prioritise basics (MFA, edge patching, EDR tamper protection).

Refs: thehackernews.com · acronis.com · darkreading.com

CryptoBandits / 'Crypto Clipper' - USB LNK worm + Tor C2 hijacks crypto wallets (Microsoft)

HIGH

VERIFIED

Clipper

Worm

Tor

Microsoft tracks CryptoBandits (active since Feb 2026): a Windows clipper that spreads via malicious .lnk files on USB drives, launches a bundled Tor proxy to a hidden-service C2, and polls the clipboard ~every 500ms to steal seed phrases/private keys and swap copied wallet addresses for the attacker's, plus screenshot exfil over Tor. Detected as Trojan/CryptoBandits.A. Disable AutoRun/AutoPlay, block .lnk execution from removable media via GPO, and restrict wscript/cscript.

Refs: microsoft.com · thehackernews.com · securityweek.com

SocGholish (FakeUpdates) infrastructure disrupted - 106 servers / domains seized (Operation Endgame)

MEDIUM

VERIFIED

Takedown

InitialAccess

EvilCorp

Operation Endgame (Dutch police/Prosecution with FBI, RCMP, German BKA, Europol, Eurojust) seized 106 servers/domains and cleaned 14,971 infected WordPress sites tied to SocGholish/FakeUpdates - the fake-update initial-access framework active since 2017 and linked to Russia's Evil Corp. Investigators found exposed creds for ~1.4M WordPress sites. Operators historically rebuild - hunt historical FakeUpdates JS injects and seized-domain traffic, and watch for successor infrastructure.

Refs: thehackernews.com · bleepingcomputer.com · cyberscoop.com

VHDX-delivered Remcos RAT (ZIP -> auto-mounted VHDX -> JavaScript -> Remcos)

MEDIUM

UNVERIFIED

RAT

Delivery

SANS

SANS ISC handler diary: a malicious ZIP (SHA256 a010...094) contains a VHDX disk image that auto-mounts on double-click in modern Windows, exposing a JavaScript payload that delivers the Remcos RAT (keylogging, screen capture, C2). VHDX is a container format that frequently evades mark-of-the-web/AV checks. Block/alert on VHDX auto-mount from downloads and hunt Remcos C2/persistence. Single-source diary (unverified).

Refs: isc.sans.edu

Unit 42 - trojanized browser-extension campaign covertly injects ads

MEDIUM

UNVERIFIED

Extension

AdInjection

Unit42

Palo Alto Unit 42 detected a campaign trojanizing legitimate browser extensions (ad-block, messaging-privacy, screen-record, music-control categories) to serve ads covertly, with 1,000+ installs observed. Trusted utility categories make this an effective abuse vector. Inventory extensions, restrict sideloading and enforce enterprise extension allowlists. Single-source vault capture (unverified).

Refs: x.com/Unit42_Intel

Brazilian HTA/VBScript loader staging from larpers[.]eu

MEDIUM

UNVERIFIED

Loader

HTA

Brazil

A Brazilian campaign uses an HTA/VBScript loader: VBScript pulls two files from larpers[.]eu into a random %TEMP% dir, renames them p.exe and hda_config.dat, runs the PE silently, then opens a decoy PDF. Block/monitor larpers[.]eu and alert on mshta.exe spawning wscript/cscript and writing PEs to %TEMP%. Single-source capture (unverified).

Refs: x.com/stop_spammerz

GLOBAL - NOTABLE BREACHES**FortiBleed - mass Fortinet firewall credential compromise (30k+ creds, 194 countries; GPU hash-cracking)**

CRITICAL

VERIFIED

Credentials

Fortinet

Campaign

SOCRadar's 'FortiBleed' campaign exposed 30,000+ (reporting also cites ~73,932 device URLs) Fortinet firewall credentials across 194 countries (US #2); victims include banks, telecom and government, and the operation is ongoing. CISA urged hardening of FortiGate devices. Multiple actors are reselling access ('SantaAd' ~34k, 'Dark_Alpha' ~35k IPs), and operators reportedly rented ~36 cloud GPUs to crack stolen FortiGate config hashes at scale - treat any config-stored creds/PSKs as crackable and rotate them, don't rely on complexity.

Refs: bleepingcomputer.com · bleepingcomputer.com · x.com/CISACyber

Kodak confirms breach - ShinyHunters claims 2.2M+ records

HIGH

VERIFIED

Breach

Extortion

ShinyHunters

Kodak confirmed an unauthorized third party accessed company data after ShinyHunters listed it (15 Jun) and claimed 2.2M+ records of customer PII and corporate data, with a leak threat dated 18 Jun. Kodak characterises it as a 'limited amount' of data and engaged external experts and law enforcement. Part of ShinyHunters' ongoing enterprise/third-party-integration extortion campaign (cf. the Salesforce/OAuth wave).

Refs: bleepingcomputer.com · securityweek.com · malwarebytes.com

Texas Parks & Wildlife (TPWD) vendor breach - 3M+ driver's licenses & passport numbers

HIGH

VERIFIED

Breach

Government

ThirdParty

A breach at TPWD's licensing-system vendor exposed driver's-license data, passport numbers, emails, phones and addresses for 3,087,721 individuals (SSNs/DOB/financial data not taken). TPWD notified Texas Cyber Command on 13 May; disclosed 18 Jun, with Kroll monitoring offered. The same actor is linked to a similar breach at Virginia's Dept. of Wildlife Resources - state hunting/fishing license systems run on a few shared SaaS platforms holding government-ID data, concentrating risk.

Refs: bleepingcomputer.com · securityweek.com · rescan.com

Brazil national emergency-alert system breached - spoofed 'Extreme Alert' pushed across states

MEDIUM

UNVERIFIED

Government

AlertSystem

Brazil

A hacker breached Brazil's national emergency alert system and pushed a spoofed 'Extreme Alert' to phones across multiple states overnight, overriding silent mode. Emergency/cell-broadcast systems are high-impact targets (mass panic, disinformation, erosion of trust). The actor was reportedly identified after leaving their CapCut ID baked into a 'brag' video (OPSEC failure). Two vault sources, same outlet chain; retained UNVERIFIED.

Refs: x.com/IntCyberDigest · x.com/IntCyberDigest

~24 billion credentials found exposed online (aggregated combolist)

MEDIUM

UNVERIFIED

Credentials

Combolist

Exposure

A database of ~24 billion credentials was reportedly found exposed online (via SC World). At this scale it is almost certainly an aggregated compilation from prior breaches and infostealer logs rather than a single new breach - but it materially lowers the bar for credential-stuffing and ATO at scale. Enforce MFA/passkeys, monitor for credential-stuffing, and check exposure via HIBP-style services. Single-source (unverified).

Refs: x.com/Dinosn

INDICATORS OF COMPROMISE (IOCs) TO ADD

Blocklist / SIEM

Indicator	Type	Context	Reference
CVE-2026-48907	CVE	Joomla JCE improper access control -> PHP RCE (10.0); fix 2.9.99.5; public exploit	thehackernews.com
CVE-2026-42530 / CVE-2026-42055	CVE	F5 NGINX HTTP/3 UAF + HTTP/2 heap overflow (9.2); fix 1.31.2 / 1.30.3	securityweek.com
CVE-2026-20253	CVE	Splunk unauth file create/truncate -> RCE (9.8); fix 10.2.4/10.0.7 - exploited	thehackernews.com
CVE-2026-46798	CVE	Oracle WebCenter Sites unauth RCE / takeover (9.8); June 2026 CPU	oracle.com
CVE-2026-20262	CVE	Cisco Catalyst SD-WAN Manager file write -> root; KEV fix-by 2026-06-29	thehackernews.com
CVE-2026-4020	CVE	Gravity SMTP WP unauth info disclosure; fix 2.1.5 - mass-exploited	bleepingcomputer.com
CVE-2026-53435	CVE	Jenkins deserialization (8.8); 2026-06-10 advisory - exploited	jenkins.io

Indicator	Type	Context	Reference
CVE-2025-20701	CVE	Airoha SoC Bluetooth eavesdrop (8.8); Beats fw 1B211	thehackernews.com
/wp-json/gravitysmtp/v1/tests/mock-data	URI (exploit)	Gravity SMTP info-disclosure request pattern in access logs	thehackernews.com
.../wildfly/standalone/deployments/*.war	Path (exploit)	Cisco SD-WAN file-write webshell staging; hunt vmanage-server.log	thehackernews.com
github[.]com/MSNightmare/RoguePlanet	URL (PoC)	Windows Defender -> SYSTEM exploit repo (Chaotic/Nightmare Eclipse)	bleepingcomputer.com
easy-day-js (npm) / @mastrascope pkgs	Malicious packages	DPRK Sapphire Sleet infostealer (dayjs typosquat); rotate dev/wallet secrets	bleepingcomputer.com
Trojan/CryptoBandits.A (USB .lnk)	Malware	Tor-C2 crypto clipper via removable media; block LNK from USB	microsoft.com
larpers[.]eu	Domain (C2)	Brazilian HTA/VBScript loader staging (p.exe / hda_config.dat)	x.com/stop_spammerz
a0104921a2d37ab87482ac9a9f5c3713479c118846c3e999178e75b81620c094	SHA256	Malicious ZIP -> VHDx -> Remcos RAT (SANS ISC)	isc.sans.edu
panel.ddins[.]click	URL (panel)	'Operador - Login' malware C2/panel (malwrhunterteam)	x.com/malwrhunterteam
rockknight[.]com , topqdns[.]com	Domains	Obfuscated samples 0/62 VT (malwrhunterteam)	x.com/malwrhunterteam
SiderAI / MaxAI (Chrome extensions)	Software	'Spyder'/'MaXSS' unpatched flaws; 10M+ installs - restrict/remove	rebora.io

Defanged indicators - re-fang before importing. Verify against your environment before blocking.

TRENDS & EMERGING THREATS TO WATCH

Forward look

HIGH

Web & enterprise apps under active mass-exploitation

Why it matters: Joomla JCE (10.0, automated), Splunk, NGINX, Oracle WebCenter, Cisco SD-WAN (KEV 0-day), Jenkins and Gravity SMTP were all exploited this week, and FortiBleed keeps widening. Public exploit code and automation compress disclosure-to-compromise to hours.

Watch for: unpatched internet-facing CMS/SIEM/CI/ERP/appliances; CISA KEV additions; webshells and rogue .war/.php uploads; anomalous appliance logins; FortiGate config-credential reuse.

HIGH

Trusted-infrastructure C2 + BYOVD EDR-killers in ransomware

Why it matters: DragonForce's Backdoor.Turn tunnels C2 through Microsoft Teams TURN relays (first seen in the wild); The Gentlemen ship GentleKiller (400 procs/48 products via vulnerable drivers); CryptoBandits and others ride Tor. Naive domain/IP blocklists and unprotected EDR fail here.

Watch for: C2 blending with Teams/QUIC/Tor traffic; vulnerable-driver loads (BYOVD) and EDR tamper/uninstalls; QoS policies throttling security agents; long dwell before encryption.

HIGH

AI as attack surface and attacker tooling

Why it matters: Unpatched Spyder/MaXSS flaws in 10M-install AI side-panel extensions, AutoJack (AutoGen MCP) and 'codeless' LLM-shell techniques sit alongside offensive AI agents (CyberStrike, CyberSentinel) and DPRK's Mastra npm poisoning - AI is now routinely both target and weapon.

Watch for: agentic browser extensions with broad permissions; exposed LLM gateways / MCP endpoints; AI dev-tool dependencies (npm/PyPI); agents acting on untrusted content without human-in-the-loop.

MED

SaaS OAuth integration-token theft against Salesforce

Why it matters: The Klue breach let 'Icarus' steal OAuth tokens and pull Salesforce data from Recorded Future, Tanium, Jamf, Gong and others - inheriting authorised access without tripping primary-app auth. Continuation of the Salesloft/Drift integration-token pattern.

Watch for: third-party SaaS integration tokens with broad scopes; anomalous Salesforce API/bulk-export activity; dormant/prototype credentials; OAuth grants from unexpected integrations.

MED

China- & DPRK-nexus espionage and supply-chain

Why it matters: SprySOCKS gained a Windows kernel-rootkit variant (FishMonger/I-Soon), DPRK's Sapphire Sleet poisoned 140+ Mastra npm packages, and Silver Fox activity continues - patient, stealthy access into developer and government estates.

Watch for: driver/sshd/binary drift vs package checksums; npm/PyPI typosquats and postinstall hooks; infostealers targeting wallet/browser extensions; kernel-rootkit behaviour hiding processes/connections.

MED

Credential-exposure economy & GPU-accelerated cracking

Why it matters: FortiBleed (30k+ creds, resold by multiple actors) now pairs with rented cloud GPUs to crack stolen FortiGate config hashes at scale, while a ~24B-credential combolist feeds credential stuffing - complexity alone no longer protects stored secrets.

Watch for: reuse of FortiGate config-stored creds/PSKs; spikes in credential-stuffing / impossible-travel logins; leaked-credential hits for your domains; absence of phishing-resistant MFA.

PRIORITY ACTIONS THIS WEEK

Area	Action
Patch now	Joomla JCE (CVE-2026-48907 -> 2.9.99.5); Splunk (CVE-2026-20253 -> 10.2.4/10.0.7); F5 NGINX (CVE-2026-42530/42055); Oracle WebCenter Sites (CVE-2026-46798, June CPU); Cisco Catalyst SD-WAN (CVE-2026-20262, by 29 Jun); Jenkins (CVE-2026-53435); Gravity SMTP (CVE-2026-4020 -> 2.1.5); Beats/Airoha (CVE-2025-20701 -> 1B211); apply June Android bulletin (CVE-2026-28575).
Block IOCs	Add the IOC-table indicators (CVE IDs, Gravity-SMTP & Cisco request patterns, RoguePlanet PoC repo, easy-day-js/@mastra npm pkgs, CryptoBandits LNK, larpers[.]eu, VHDX SHA256, painel.ddins[.]click, rockknight[.]com/topqdns[.]com) to firewall/EDR/SIEM blocklists and alert on the listed CVEs.
Assume compromise	Treat internet-exposed Joomla/JCE, Splunk, Oracle WebCenter, Cisco SD-WAN and exposed FortiGate as potentially compromised - hunt webshells/.war drops, anomalous file writes and exfil; rotate appliance & FortiGate config secrets.
Detect stealth C2 / BYOVD	Hunt C2 blending with Teams/QUIC/Tor; enable Microsoft vulnerable-driver blocklist and EDR tamper protection; alert on driver loads (BYOVD) and QoS policies throttling security agents.
Supply chain & identity	Audit @mastra/npm deps and pin+hash-verify; rotate developer/CI/cloud & wallet secrets; revoke/rotate Salesforce OAuth integration tokens and review bulk-export logs; move to FIDO2/passkeys.
Endpoints & AI	Disable AutoRun and block LNK execution from USB (GPO); restrict wscript/cscript; review/remove SiderAI & MaxAI extensions; restrict exposure of LLM gateways/MCP endpoints.
People & vendors	Brief staff on permission-prompt and AI-tool phishing; re-review third-party SaaS/DB access for AU/APAC entities; given INC's AU targeting, validate backup immutability (esp. Veeam/DPAPI).